Seguridad frontend en PharmaSoft

Guía práctica de la sesión 11 | Matriz de verificación y espacios para evidencias

Estudiante	Ruben Yactayo Varillas	**Asignatura**	Lenguaje de Programación II
Proyecto	PharmaSoft	**Sesión**	11 · 2026-2
Alcance	Reto 01 · SPA Angular	**Pruebas**	16 escenarios del paso 11

Propósito

Este documento acompaña la verificación de la SPA PharmaSoft conectada con PharmaBackend. Describe el flujo de seguridad esperado y reserva una página por cada una de las 16 pruebas prácticas. Inserta una captura real en el espacio señalado y completa el resultado observado; no se han marcado pruebas como aprobadas antes de ejecutarlas.

Cómo funciona el flujo de seguridad

- El login envía usuario y contraseña al endpoint de autenticación. Si el backend los acepta, la SPA guarda token, usuario, roles, permisos y vencimiento de la sesión.
- La sesión se conserva en sessionStorage para sobrevivir una recarga del navegador y se descarta al cerrar sesión o al vencer el token.
- El interceptor de autenticación debe adjuntar el token Bearer solo a solicitudes dirigidas a la API. El interceptor de errores debe cerrar la sesión ante 401, salvo en el login, y conservarla ante 403.
- Los guards de sesión y permiso controlan la navegación. El menú y los botones se muestran de acuerdo con los permisos; el backend mantiene la protección efectiva de los datos.

Responsabilidad de cada componente

AuthService centraliza el inicio y cierre de sesión, conserva el estado en una señal compartida y programa el vencimiento. El interceptor de autenticación añade Authorization: Bearer a las solicitudes protegidas; el interceptor de errores interpreta las respuestas 401 y 403. Los guards revisan la sesión y el permiso antes de activar rutas, mientras que la directiva appSiPermiso oculta controles de escritura en la interfaz.

Cómo interpretar la respuesta

HTTP 401 significa que falta una sesión válida, el token venció o fue alterado; la SPA debe limpiar la sesión y pedir que se inicie sesión otra vez. HTTP 403 significa que el usuario sí está autenticado pero su rol no tiene el permiso requerido; en ese caso debe conservar la sesión y mostrar acceso denegado. Ocultar un botón mejora la experiencia, pero la decisión final siempre corresponde al backend.

Estado de la evidencia

Las páginas siguientes indican el procedimiento, el resultado esperado y qué debe verse en cada captura. Completa Resultado observado y selecciona Pasa o Falla después de ejecutar el caso con el backend y ng serve activos.

Importante: oculta contraseñas y evita mostrar el token JWT completo en las capturas.

Matriz de pruebas

Casos del paso 11 de la guía práctica. El nombre de archivo sugerido corresponde a la evidencia de cada prueba.

Ejecuta las pruebas en orden cuando una dependa de otra. Usa las cuentas y datos locales de la guía, no marques un caso como aprobado solo porque la pantalla se ve correcta: comprueba también la URL, la petición o la respuesta indicada.

N.º	Prueba	Resultado esperado	Captura
01	**Sin sesión y returnUrl**	La SPA muestra el login con returnUrl que apunta a /ventas.	Evidencia_01.png
02	**Validación del login vacío**	Se muestran los mensajes de validación de ambos campos y no se envía una petición de login.	Evidencia_02.png
03	**Credenciales incorrectas**	El formulario permanece en /login y muestra «Usuario o contraseña incorrectos» (401).	Evidencia_03.png
04	**Cuenta inactiva**	Muestra el mismo mensaje genérico de credenciales incorrectas; no revela que la cuenta existe o está deshabilitada.	Evidencia_04.png
05	**Vendedor vuelve a la página solicitada**	Vuelve a /ventas. El encabezado muestra nombre, rol y hora de expiración.	Evidencia_05.png
06	**Interceptor agrega el token**	GET /productos incluye Authorization: Bearer; POST /auth/login no incluye Authorization.	Evidencia_06.png
07	**Sesión en sessionStorage**	Existe la clave pharmasoft.sesion con token, expiraEn, username, roles y permisos.	Evidencia_07.png
08	**La sesión sobrevive a F5**	La sesión se recupera desde sessionStorage y permanece en la misma página.	Evidencia_08.png
09	**Vendedor solo lectura de productos**	No aparecen Nuevo producto, Editar, Dar de baja ni la columna Acciones.	Evidencia_09.png
10	**Ruta de escritura protegida**	Se muestra «403 · Acceso denegado».	Evidencia_10.png
11	**Login protegido para invitados**	invitadoGuard redirige a /inicio.	Evidencia_11.png
12	**Cerrar sesión**	Vuelve a /login y desaparece pharmasoft.sesion.	Evidencia_12.png
13	**Almacenero sin módulo Ventas**	Ventas no aparece en el menú y la URL directa muestra Acceso denegado.	Evidencia_13.png
14	**Supervisor combina permisos**	Ve Ventas y, en Productos, dispone de acciones de edición del catálogo.	Evidencia_14.png
15	**Token alterado**	El backend responde 401; la SPA elimina la sesión y vuelve al login con «Su sesión expiró».	Evidencia_15.png
16	**Expiración automática**	Al vencer, la SPA vuelve al login con «Su sesión expiró»; al entrar de nuevo, vuelve a la página que estaba abierta.	Evidencia_16.png

EVIDENCIA 01 | Sin sesión y returnUrl

Acción: Sin sesión, abre http://localhost:4200/ventas.

Resultado esperado: La SPA muestra el login con returnUrl que apunta a /ventas.

Qué comprueba: Esta comprobación valida la protección de una ruta privada cuando no existe una sesión válida. El parámetro returnUrl conserva el destino solicitado para que el usuario pueda continuar allí después de autenticarse.

La captura debe mostrar: Se ve la URL del navegador y el formulario de login.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 02 | Validación del login vacío

Acción: Pulsa Ingresar sin completar usuario ni contraseña.

Resultado esperado: Se muestran los mensajes de validación de ambos campos y no se envía una petición de login.

Qué comprueba: La validación del formulario actúa antes de llamar al backend: los controles requeridos muestran sus errores y se evita enviar una petición incompleta. La ausencia del POST confirma que la validación del lado del cliente funcionó.

La captura debe mostrar: El formulario con los dos errores y Network sin POST /auth/login.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 03 | Credenciales incorrectas

Acción: Intenta iniciar sesión como admin con una contraseña incorrecta.

Resultado esperado: El formulario permanece en /login y muestra «Usuario o contraseña incorrectos» (401).

Qué comprueba: El backend compara las credenciales y rechaza el intento con HTTP 401. La interfaz presenta un mensaje general y mantiene el formulario disponible para corregir los datos sin revelar información de la cuenta.

La captura debe mostrar: Mensaje del formulario y, si cabe, la petición de login con estado 401.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 04 | Cuenta inactiva

Acción: Intenta iniciar sesión como inactivo con Inactivo2026*.

Resultado esperado: Muestra el mismo mensaje genérico de credenciales incorrectas; no revela que la cuenta existe o está deshabilitada.

Qué comprueba: Una cuenta deshabilitada no debe obtener una sesión aunque la contraseña sea correcta. La respuesta y el mensaje genérico permiten verificar el rechazo sin revelar si el usuario está registrado o inactivo.

La captura debe mostrar: Mensaje y respuesta 401; evita mostrar contraseñas.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 05 | Vendedor vuelve a la página solicitada

Acción: Desde el login que conserva returnUrl=/ventas, entra con vendedor / Vendedor2026*.

Resultado esperado: Vuelve a /ventas. El encabezado muestra nombre, rol y hora de expiración.

Qué comprueba: Después de un inicio de sesión válido, la SPA conserva la información devuelta por la API y usa returnUrl para recuperar el flujo interrumpido. El encabezado permite comprobar la identidad y los roles asociados a la sesión.

La captura debe mostrar: Página de ventas y encabezado con la sesión de vendedor.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 06 | Interceptor agrega el token

Acción: En Network, selecciona GET /productos y compara con POST /auth/login.

Resultado esperado: GET /productos incluye Authorization: Bearer; POST /auth/login no incluye Authorization.

Qué comprueba: El interceptor agrega el encabezado Authorization a las llamadas protegidas de la API cuando hay una sesión. El endpoint de login queda excluido porque debe recibir credenciales antes de que exista un token válido.

La captura debe mostrar: DevTools Network mostrando los encabezados de ambas peticiones. Oculta el token completo.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 07 | Sesión en sessionStorage

Acción: Abre Application > Session Storage para localhost:4200.

Resultado esperado: Existe la clave pharmasoft.sesion con token, expiraEn, username, roles y permisos.

Qué comprueba: La sesión serializada reúne la información que la SPA necesita para restaurarse tras una recarga: token, vencimiento, usuario, roles y permisos. El token debe ocultarse en la evidencia porque permite representar temporalmente la sesión.

La captura debe mostrar: Panel Session Storage con la clave y campos visibles; oculta el valor íntegro del token.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 08 | La sesión sobrevive a F5

Acción: Con vendedor en Productos, pulsa F5.

Resultado esperado: La sesión se recupera desde sessionStorage y permanece en la misma página.

Qué comprueba: Al actualizar el navegador, el servicio de autenticación vuelve a leer la sesión guardada y reconstruye el estado que utilizan el encabezado, el menú y los guards. Esta prueba comprueba que F5 no obliga a ingresar de nuevo.

La captura debe mostrar: Página Productos tras recargar y sesión conservada.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 09 | Vendedor solo lectura de productos

Acción: Con vendedor, abre Productos.

Resultado esperado: No aparecen Nuevo producto, Editar, Dar de baja ni la columna Acciones.

Qué comprueba: El permiso de lectura permite consultar el catálogo, mientras que las acciones de escritura requieren CATALOGO_ESCRIBIR. La prueba comprueba que la interfaz no ofrezca operaciones que el rol VENDEDOR no tiene autorizadas.

La captura debe mostrar: Tabla de Productos completa mostrando que no hay controles de escritura.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 10 | Ruta de escritura protegida

Acción: Con vendedor, escribe directamente /productos/nuevo.

Resultado esperado: Se muestra «403 · Acceso denegado».

Qué comprueba: La restricción se verifica también al escribir la dirección directamente, sin depender de que el botón esté oculto. El guard de permisos debe impedir que la navegación manual abra el formulario de escritura.

La captura debe mostrar: URL directa y página de acceso denegado.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 11 | Login protegido para invitados

Acción: Con una sesión activa, escribe /login.

Resultado esperado: invitadoGuard redirige a /inicio.

Qué comprueba: Una persona autenticada no necesita volver al login. El guard de invitados evita mostrar el formulario y dirige al usuario a una página interna de la aplicación.

La captura debe mostrar: URL final y encabezado de la sesión activa.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 12 | Cerrar sesión

Acción: Pulsa Cerrar sesión y revisa Session Storage.

Resultado esperado: Vuelve a /login y desaparece pharmasoft.sesion.

Qué comprueba: Cerrar sesión elimina la sesión de sessionStorage y limpia el estado reactivo de autenticación. Por ello, las siguientes rutas privadas deben requerir un nuevo inicio de sesión.

La captura debe mostrar: Login y panel Session Storage sin la clave de sesión.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 13 | Almacenero sin módulo Ventas

Acción: Inicia sesión como almacen / Almacen2026*; luego escribe /ventas.

Resultado esperado: Ventas no aparece en el menú y la URL directa muestra Acceso denegado.

Qué comprueba: El rol ALMACENERO puede trabajar con el catálogo, pero no tiene permiso VENTAS_LEER. Se comprueba tanto la opción del menú como el bloqueo de la ruta para evitar depender solo de la navegación visual.

La captura debe mostrar: Página denegada; si es posible muestra también el menú sin Ventas.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 14 | Supervisor combina permisos

Acción: Inicia sesión como supervisor / Supervisor2026*.

Resultado esperado: Ve Ventas y, en Productos, dispone de acciones de edición del catálogo.

Qué comprueba: Los permisos efectivos se forman con los roles asignados a la cuenta. La cuenta de supervisión combina lectura y escritura del catálogo con acceso a ventas, por lo que debe mostrar ambos conjuntos de opciones.

La captura debe mostrar: Menú con Ventas y Productos con controles de escritura.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 15 | Token alterado

Acción: En Session Storage cambia un carácter del token del vendedor y pulsa F5.

Resultado esperado: El backend responde 401; la SPA elimina la sesión y vuelve al login con «Su sesión expiró».

Qué comprueba: Cambiar un carácter altera el JWT almacenado, pero no crea una firma válida. Al volver a consultar la API, el backend debe rechazarlo con 401 y el interceptor debe limpiar la sesión local y mostrar el aviso de expiración.

La captura debe mostrar: Login con el aviso de expiración y respuesta 401. No muestres el token completo.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

EVIDENCIA 16 | Expiración automática

Acción: Configura app.jwt.expiracion-minutos=1, reinicia el backend, inicia sesión y espera a que venza. Luego restaura el valor a 60.

Resultado esperado: Al vencer, la SPA vuelve al login con «Su sesión expiró»; al entrar de nuevo, vuelve a la página que estaba abierta.

Qué comprueba: El temporizador de la SPA se calcula a partir de la expiración informada al iniciar sesión. Al vencer, cierra la sesión y conserva la ruta para retomarla tras autenticarse; al finalizar, debe restaurarse la configuración normal del backend.

La captura debe mostrar: Pantalla de login con aviso y, tras volver a entrar, URL recuperada. Anota que el valor del backend se restauró a 60.

Resultado observado: _____ Estado: ☐ Pasa ☐ Falla

PEGAR CAPTURA AQUÍ

Sustituye este texto por la captura completa de la prueba.

Al terminar esta prueba, restaura app.jwt.expiracion-minutos a 60 y reinicia PharmaBackend.